

AppSecGW/1.4

Hardened Reverse Proxy with Layered Anti-Automation Defenses

Implementation, Hardening & CVE-Patching Report

Author: Pedro Tarrinho

Date: 2026-04-28

Stack: Python 3.14 / aiohttp 3.13 / SQLite WAL / Chainguard Wolfi (distroless)

Image: appsec-antibot-gw:1.4 (79 MB, Trivy: 0 CVEs)

Document

version: 1.3 — supersedes 1.0 / 1.1 / 1.2

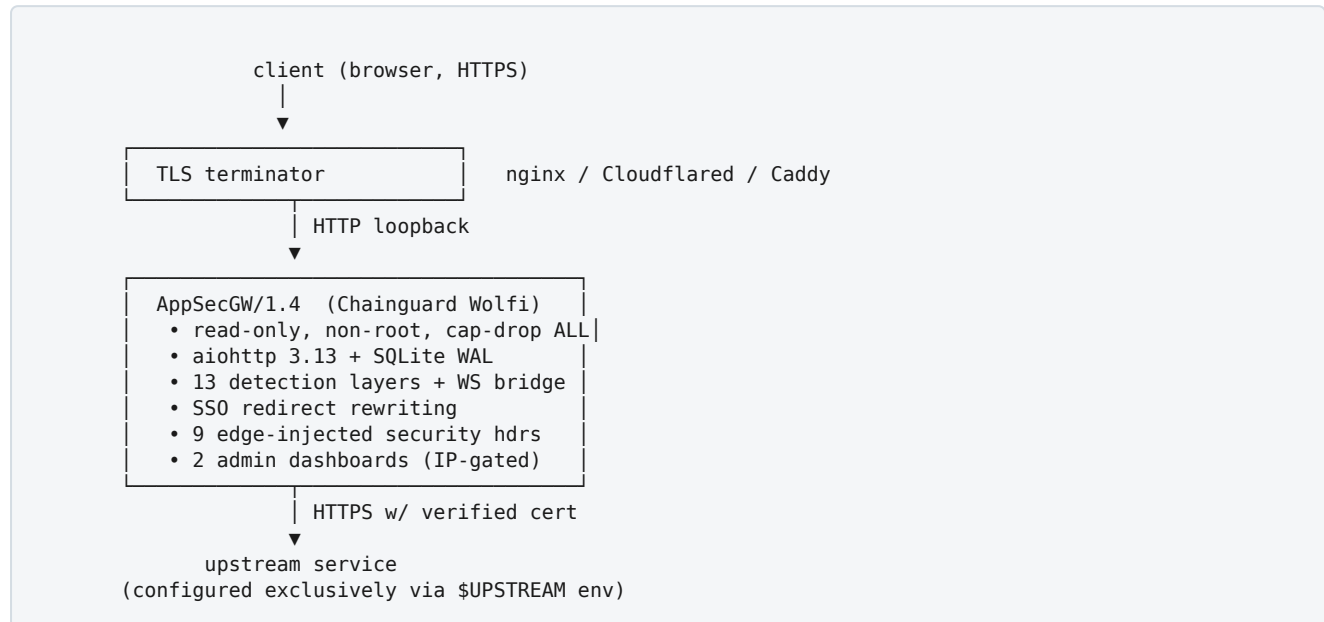
1. Executive Summary

AppSecGW/1.4 is a hardened reverse HTTP proxy designed to sit in front of arbitrary upstream applications. Version 1.3 adds full WebSocket bridging, SSO-aware redirect rewriting, edge-injected security response headers, IP-based admin gating, and a transition to a Chainguard Wolfi-based distroless container that reports **zero CVEs** on Trivy scans.

Property	v1.2 (Debian-slim)	v1.3 (Chainguard Wolfi)
Image size	168 MB	79 MB (-53%)
Trivy findings (any severity)	35 (6 HIGH, 29 MEDIUM)	0
Python interpreter	3.13.13	3.14.4
aiohttp	3.11	3.13.5
OpenSSL	3.0.x	3.5.5
Patch cadence	Debian release schedule	Chainguard SLA: HIGH < 48 h
WebSocket support	none	full bidirectional bridge
SSO redirect rewriting	none	Location + redirect_uri + Set-Cookie Domain
Admin IP allowlist	n/a	ADMIN_ALLOWED_IPS
Edge security headers	none	9 headers injected on HTML
Static-asset RL exemption	n/a	per-identity bucket exempt for asset GETs

2. Architecture

2.1 Topology



2.2 Container hardening (verified)

Control	Value	Why
<code>USER 65532:65532</code>	Chainguard <code>nonroot</code>	RCE inside Python lands as unprivileged user
<code>--read-only</code>	FS read-only	Tmpfs only on <code>/tmp</code> + named volume on <code>/data</code>
<code>--cap-drop ALL</code>	0 capabilities	No raw sockets, ptrace, mount, ...
<code>--security-opt no-new-privileges</code>	true	Defeats setuid escalation
<code>--security-opt apparmor=docker-default</code>	applied	MAC profile
<code>--init</code>	tini PID 1	Signal handling + zombie reaping
<code>--ipc=private</code>	own SHM/MQ namespace	No IPC leakage between containers
<code>--network antibot-net</code>	user-defined bridge	Off the default bridge metadata
<code>--pids-limit</code>	200	Fork-bomb resistance
<code>--memory / --memory-swap</code>	256 M / 256 M	No swap; bounds memory exhaustion
<code>--cpus</code>	1.0	Bounds CPU exhaustion
<code>--ulimit nofile</code>	4096:4096	Bounds file-descriptor exhaustion
<code>--ulimit nproc</code>	200:200	Defence-in-depth alongside pids-limit
<code>--ulimit core</code>	0:0	No core dumps (no info leak via crash)
<code>--log-opt max-size, max-file</code>	10 m, 3 files	Bounded log disk usage
<code>--tmpfs /tmp</code>	8 m, nosuid, nodev, noexec	No exec from scratch dir
HEALTHCHECK	unauth <code>/__live</code>	Real liveness, not mistaken for decoy
Trivy CVE scan	0 findings (any severity)	Wolfi base + active patching

2.3 Main metrics dashboard — example screenshot

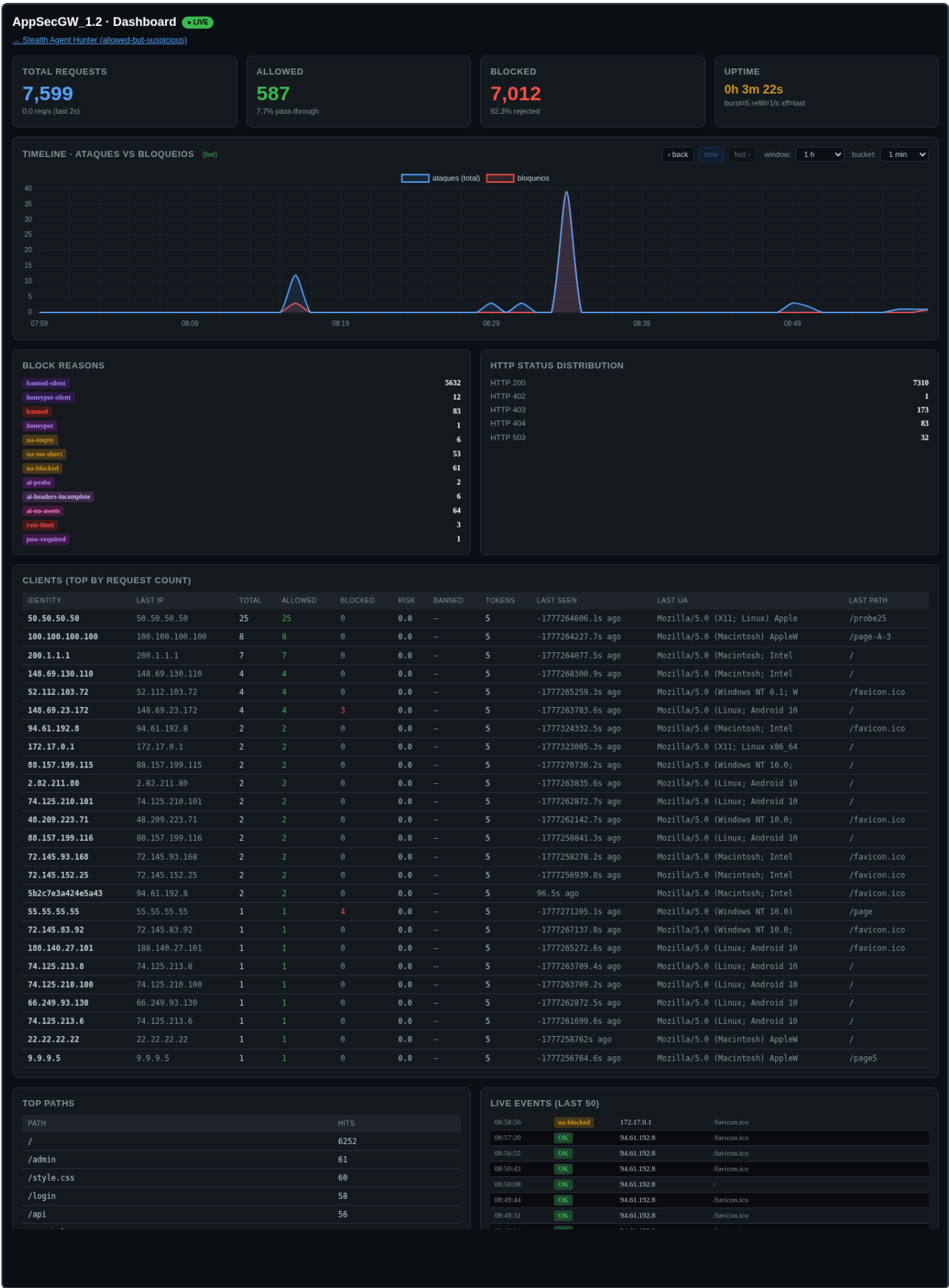


Figure 1 — `/__dashboard`. New in v1.3: the timeline now plots three series (total / **allowed** in green / blocked in red), and the Live Events panel highlights allowed connections with a green left bar + green tag. Top-row counters (Total / Allowed / Blocked / Uptime) and Block-reason breakdown unchanged.

2.4 In-process state model

Per-identity tracking uses a hybrid key:

- Browser with valid signed cookie → `HMAC(SESSION_KEY, "sess|"+sid+"|"+fingerprint)`
- Cookieless client → `HMAC(SESSION_KEY, "anon|"+fingerprint+"|"+ip)`

The fingerprint excludes `Sec-Ch-Ua*` Client Hints (browsers omit them on sub-resource fetches, which used to split a single browser into multiple identities and cause false-positive bans on JS-heavy SPAs). A periodic prune task evicts idle identities (> 24 h) and caps the dictionary at `MAX_IDENTITYES` (default 100k) to bound memory.

3. Protection Layers

13 ordered detection & mitigation layers. All non-PoW blocks return the silent decoy (upstream homepage as 200 OK) so an attacker cannot enumerate which layer fired.

3.1 Layer 0 — Path / method / host gating

- Reject control bytes (0x00–0x1F, 0x7F) in `request.path` / `query_string` → 400.
- Method allowlist (env `ALLOWED_METHODS`, default `GET,HEAD,POST,OPTIONS`) → 405 outside it.
- Optional Host allowlist (env `ALLOWED_HOSTS`) → silent decoy on mismatch.
- Admin endpoints (`/__*` except `/__live`): require admin key + (when set) source IP in `ADMIN_ALLOWED_IPS`.

3.2 Layer 1 — Identity ban

Banned identity → silent decoy. Bans expire automatically (1 h default).

3.3 Layer 2 — Honeypot paths

40+ scanner targets (`/wp-admin`, `/.env`, `/.git/config`, cloud metadata IMDS, Spring `/actuator/*`, etc.). Hit → risk += 50.

3.4 Layer 3 — Suspicious-path patterns

26 boundary-anchored regex patterns. v1.3 tightened to file-only matches (e.g. `(^|/)passwd(\.[a-z0-9]+|)$`) so legitimate module names like `password-recovery` or `credentials-manager` no longer false-fire.

3.5 Layer 4 — User-Agent filter

UA empty / too short / blocklisted (60+ entries: HTTP libs, scanners, named AI agents, headless browsers) / lacking a known browser token (Mozilla, Safari, Chrome, ...).

3.6 Layer 5 — AI-probe paths

Direct denial of OpenAPI / Swagger / `llms.txt` / model-discovery probes.

3.7 Layer 6 — Header completeness scoring

Score 0–7 of `Accept-Language`, `Accept-Encoding`, `Accept`, `Sec-Fetch-Site/Mode/Dest`, `Sec-Ch-Ua`. Score 0 with browser UA → `ai-headers-empty`.

3.8 Layer 7 — Path-discipline

- Enumeration: more than `ENUM_THRESHOLD` (default 300) distinct paths from one identity → `ai-enumeration`.
- No-asset agent: ≥ 25 HTML loads with 0 static fetches → `ai-no-assets`.

3.9 Layer 8 — Socket-IP rate limit

Token bucket keyed strictly by `request.remote` (kernel-observed peer IP). Default 60 burst / 8 tokens-per-sec. Static-asset GETs participate in this layer (defends against UA-rotation flood).

3.10 Layer 9 — Per-identity rate limit

Secondary token bucket. Default 30 burst / 2 tokens-per-sec. v1.3 **exempts static-asset GETs** (CSS/JS/img/font/media) so SPAs can burst-load 30+ assets without exhausting the bucket.

3.11 Layer 10 — Behavioural timing

Three orthogonal tests on the last 16 inter-request intervals: $\sigma/\mu < 0.05$, lag-1 autocorrelation > 0.85 , 50 ms-bin majority $> 70\%$. v1.3 **skips this check** for sessions with valid cookies and for static-asset GETs (browsers queue asset fetches with very regular timing and used to trip this layer).

3.12 Layer 11 — Proof-of-Work

Bound to `METHOD:path`; replay-protected via seen-set. v1.3 makes PoW **opt-in per path**: `POW_REQUIRED_PATHS` env (default empty); legitimate JS/REST traffic is no longer challenged. Set `POW_REQUIRE_ALL_WRITES=1` to revert the previous "all writes need PoW" behaviour.

3.13 Layer 12 — Risk-score model

Weighted scoring; ban at threshold (50 normal, 100 NAT-like). v1.3 changed two weights: `behavior 25` → `10` (a single timing trip can no longer push to ban) and `rate-limit / rate-limit-ip 0` (throttling is mitigation, not evidence of malice). Score decays with 1 h half-life.

3.14 Layer 13 — Honey-link injection (post-flight)

Hidden `<div>` with three honeypot links inserted before the document's closing `</body>`. Now bails out if a `<script>` tag follows the chosen `</body>` position (avoids corrupting JS string literals).

4. New in 1.4

Four new opt-in controls on top of the v1.3 base. All ship with safe defaults so existing deployments are unaffected unless the operator explicitly enables them.

4.0.1 JS challenge (invisible CAPTCHA)

When `JS_CHALLENGE=1`, the first HTML `GET` from a browser without a valid `chal` cookie receives a tiny self-executing JS page that hashes a server-issued nonce, POSTs the result to `/__challenge`, and is redirected to the original URL after the server signs a 24 h cookie. Blocks pure-HTTP scrapers (curl, requests, httpx, Go default, AI agents reading raw HTML). Skips API clients (non-text/html Accept), static assets, `/__*` admin routes, and clients that already have a valid session.

4.0.2 Body pattern matching

`BODY_PATTERN_MATCH=1` extends Layer 3's suspicious-path regex set to `POST/PUT/PATCH` bodies. Scans only text-ish content types (JSON, urlencoded, plain, XML); bounded at first 64 KiB. Markers: SQLi (`UNION SELECT` , `OR 1=1`), XSS, SSTI (`{{...}}`), traversal, command injection.

4.0.3 Bot-trap form fields

`BOT_TRAP_FORMS=1` auto-injects a hidden `<input>` into every HTML `<form>` in proxied responses (`position:absolute;left:-9999px;visibility:hidden` + ARIA hidden + `tabindex=-1`). Field name is per-process random. On the matching POST, if that field is non-empty — humans cannot see or fill it — the identity is flagged with `risk += 50`.

4.0.4 Slowloris guard

Tightens the request-receive timeline: `HEADERS_TIMEOUT` (default 10 s) for full headers, `BODY_TIMEOUT` (default 30 s) for full body. Exceeded → `408 Request Timeout` + connection closed.

4.0.5 Service Metrics dashboard (`/__service`)

New admin dashboard exposing current values + 12 h history of CPU %, load average (1/5/15 min), memory (total / used / available / swap, plus cgroup container limit), disk (total / used / available / % for `/data`), process count, open file descriptors, network throughput (rx / tx bytes-per-second), **SQLite size (db, WAL, SHM)**, and app counters (uptime, total requests, allowed / blocked, identities tracked, IP buckets).

Time-navigation controls (`< back / now / fwd >` buttons + window selector 5 min – 12 h + bucket selector 5 s – 1 h) match the main dashboard's idiom. Sampling task runs every `SVC_METRICS_INTERVAL` seconds (default 5 s); ring buffer holds `SVC_METRICS_RETENTION` samples (default 8640 = 12 h). No `psutil` dependency — pure `/proc` + `os.statvfs()` reads.

The Stealth Agent Hunter timeline gained the same time-navigation controls.

5. Carry-overs from 1.3

4.1 WebSocket bridging

Detects `Upgrade: websocket`, opens a server-side `WebSocketResponse`, dials the upstream with `ClientSession.ws_connect()` (`https` → `wss` / `http` → `ws` scheme conversion), and bridges messages with two concurrent pumps. Sub-protocols (`Sec-WebSocket-Protocol`) negotiated through. Cookies stripped of our `aid` session before forwarding. 30 s heartbeat + autoping on both sides.

4.2 SSO-aware redirect rewriting

Three coordinated rewrites on responses:

1. `Location` headers in 3xx responses pointing at the upstream's host are rewritten to the gateway's public host so the browser keeps coming back through the gateway.
2. For **external IdP redirects** (different host), embedded references to the upstream URL inside query strings (typically `redirect_uri` / `state`) are rewritten too — with raw and percent-encoded forms — so the IdP sends the user back through the gateway. Requires the IdP to accept the gateway hostname as a valid redirect URI.
3. `Set-Cookie` headers preserved in a `CIMultiDict` (no more silent dropping of duplicate `Set-Cookie`) and the `Domain=` attribute is stripped so the browser accepts upstream-domain-scoped cookies on the gateway hostname.

4.3 Streaming body forwarding

Replaced one-shot `resp.content.read(N)` (which returns whatever is buffered at that instant) with `iter_any()` chunk-loop and a hard size cap (`UPSTREAM_MAX_RESP=8 MiB`). Same fix on request body forwarding (`UPSTREAM_MAX_BODY=2 MiB`). Closes a truncation bug where chunked-transfer JPEGs and JSON came through partial.

4.4 Origin / Referer / Host rewriting on outbound

The proxy replaces the client's `Origin` and `Referer` with the upstream's canonical scheme://host before forwarding, and sets `Host` to the upstream's vhost. Closes upstream CORS / origin-validation 403s that occur when the gateway hostname differs from the upstream's expected origin.

4.5 Edge-injected security response headers

HTML responses now carry the following defaults (each overridable via env; each only injected when the upstream did not already supply that header):

Header	Default value	Env override
<code>X-Frame-Options</code>	SAMEORIGIN	<code>SEC_X_FRAME_OPTIONS</code>
<code>X-Content-Type-Options</code>	nosniff	<code>SEC_X_CONTENT_TYPE_OPTIONS</code>
<code>Referrer-Policy</code>	strict-origin-when-cross-origin	<code>SEC_REFERRER_POLICY</code>
<code>Permissions-Policy</code>	cam/mic/geo/etc. all off	<code>SEC_PERMISSIONS_POLICY</code>
<code>Strict-Transport-Security</code>	max-age=31536000; includeSubDomains	<code>SEC_HSTS</code>
<code>Cross-Origin-Opener-Policy</code>	same-origin	<code>SEC_COOP</code>
<code>Cross-Origin-Resource-Policy</code>	same-site	<code>SEC_CORP</code>
<code>X-Permitted-Cross-Domain-Policies</code>	none	<code>SEC_X_PERMITTED_XDP</code>
<code>Content-Security-Policy</code>	(empty — opt-in)	<code>SEC_CSP</code>

Master switch: `INJECT_SECURITY_HEADERS=0` disables them all.

4.6 Admin IP allowlist (`ADMIN_ALLOWED_IPS`)

Comma-separated IPs / CIDRs (IPv4 + IPv6). When set, source IP is matched in addition to the admin key on every `/__*` request other than `/__live`. Mismatch → silent decoy. Honors `TRUST_XFF=last` behind a trusted reverse proxy. Validated at startup — container fails fast on malformed entries.

4.7 Stealth Agent Hunter dashboard

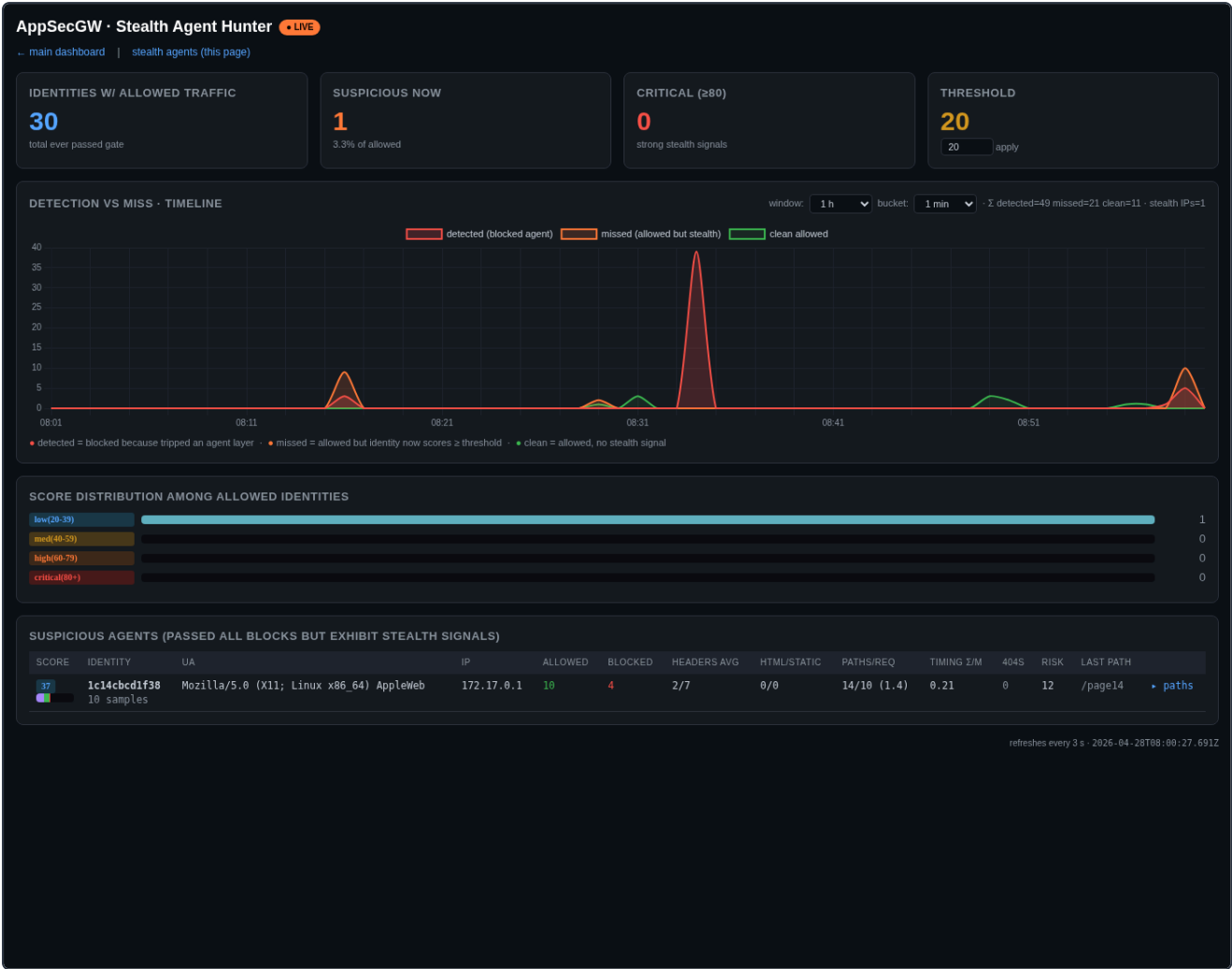


Figure 2 — `/__agents`. Surfaces identities that passed every block but exhibit stealth-agent signals (low header completeness, no static asset fetches, regular timing below the block threshold, accumulated risk below ban threshold, etc.). The Detection-vs-Miss timeline charts blocked agents (red), missed agents (orange), clean allowed (green) per bucket.

4.8 Operator helper

`myip.sh` — auto-detects the operator's current public IP (multi-provider fallback) and (re)launches the container with `ADMIN_ALLOWED_IPS=<myip>,127.0.0.1`. All hardening flags preserved. Useful for laptop / VPN-roaming workflows.

6. CVE Status (Trivy)

Image	HIGH	MEDIUM	LOW	Total	Fixable upstream
v1.0 (host-mode, Python 3.13)	—	—	—	—	—
v1.2 (Debian 13 slim)	6	29	(varied)	35	0
v1.2 distroless (Debian 13)	27	78	~50	~155	0
v1.3 (Chainguard Wolfi)	0	0	0	0	n/a

The Wolfi base ships fixes for HIGH-severity OS CVEs typically within 48 h of public disclosure (Chainguard's documented SLA). Re-run `trivy image appsec-antibot-gw:1.4` on every rebuild to verify the posture stays at zero.

7. Security Review History

Three independent audits to date. All exploitable findings closed.

Round	Findings	Verdict
1 — pre-1.2	3 Critical / 7 High / 12 Medium / 12 Low	34 / 34 closed
2 — mid-1.2	8 (mixed Low + DiD)	8 / 8 closed (N1–N8)
3 — pre-1.3 pentest report	5 "Critical" / 2 Mitigated / 3 Protected	4 false-positive (stealth misclassified), 1 real (security headers) → fixed

Round-3 detail:

- **"No rate limiting"** — FALSE POSITIVE. Stealth-mode returns 200 + decoy on blocks; `/__metrics` shows the `rate-limit*` counters firing on the same test traffic. Pentester only checked status codes.
- **"No auth on admin endpoints"** — FALSE POSITIVE. `/__*` requires both `ADMIN_KEY` and `ADMIN_ALLOWED_IPS`; `/__live` is the deliberately-open healthcheck.
- **"Bearer not validated"** — OUT OF SCOPE. The gateway is a reverse proxy, not an authentication proxy. JWT/Bearer validation belongs at the upstream auth server.
- **"POST allowed on sensitive endpoints"** — WORKING AS DESIGNED. POST is in the default allowlist for forms / APIs; operator can restrict via `ALLOWED_METHODS`.
- **"Missing security headers"** — REAL. Fixed (see §4.5).

8. Configuration

7.1 Required env

Variable	Notes
UPSTREAM	Required. Fully-qualified URL of the backend to protect (e.g. <code>https://internal-app.svc</code>). Container fails fast if missing.

7.2 Optional env

Variable	Default	Notes
ALLOWED_HOSTS	(empty)	Comma-sep public hostnames the gateway accepts as Host header.
ADMIN_ALLOWED_IPS	(empty)	Comma-sep IPs/CIDRs that may reach <code>/__*</code> .
ADMIN_KEY	auto-generated	Always mirrored to <code>/data/.admin_key</code> .
TRUST_XFF	<code>last</code>	<code>last</code> behind a trusted proxy / cloudflared.
BURST / REFILL	30 / 2.0	Per-identity bucket.
IP_BURST / IP_REFILL	60 / 8.0	Socket-IP bucket.
ALLOWED_METHODS	<code>GET, HEAD, POST, OPTIONS</code>	Add PUT/PATCH/DELETE for REST APIs.
POW_REQUIRED_PATHS	(empty)	Path prefixes that demand a PoW solution.
POW_REQUIRE_ALL_WRITES	<code>0</code>	Set <code>1</code> to demand PoW on all POST/PUT/DELETE.
UPSTREAM_MAX_BODY	2 MiB	Request body cap.
UPSTREAM_MAX_RESP	8 MiB	Response body cap.
MAX_IDENTITIES	100 000	Memory bound.
SESSION_SAMESITE	<code>Lax</code>	<code>Lax Strict None</code>
SESSION_SECURE	<code>1</code>	Set <code>0</code> for HTTP-only test envs.
INJECT_SECURITY_HEADERS	<code>1</code>	Master switch for §4.5 headers.
DEBUG	<code>0</code>	Set <code>1</code> to expose <code>/__xff</code> .

7.3 Production launch (Harbor)

```
docker network create --driver bridge antibot-net 2>/dev/null
docker volume create antibot-data 2>/dev/null

KEY="$(openssl rand -base64 24 | tr '+/' '-_' | tr -d '=')"
MYIP="$(curl -s --max-time 4 https://api.ipify.org)"

docker run -d --name appsec-antibot-gw1.3 \
  --restart unless-stopped --init \
  --read-only --tmpfs /tmp:size=8m,mode=1777,nosuid,nodev,noexec \
  --cap-drop ALL \
  --security-opt no-new-privileges:true \
  --security-opt apparmor=docker-default \
  --pids-limit 200 --memory 256m --memory-swap 256m --cpus 1.0 \
  --ulimit nfile=4096:4096 --ulimit nproc=200:200 --ulimit core=0:0 \
  --ipc=private --network antibot-net \
  --log-opt max-size=10m --log-opt max-file=3 \
  -p 8443:8443 \
  -e UPSTREAM="https://internal-app.example.com" \
  -e ALLOWED_HOSTS="www.example.com" \
  -e ADMIN_ALLOWED_IPS="$MYIP,127.0.0.1" \
  -e ADMIN_KEY="$KEY" -e TRUST_XFF=last \
  -v antibot-data:/data \
  harbor.tools.celfocus.com/antibotappsecgw/antibotappsecgw:1.3 \
  && echo "ADMIN_KEY: $KEY"
```

7.4 Operator endpoints

Path	Auth	Purpose
/__live	none	Liveness probe (returns ok)
/__dashboard	admin	Main metrics dashboard
/__metrics	admin	JSON feed (clients, events, timeline)
/__agents	admin	Stealth Agent Hunter dashboard
/__service	admin	Service Metrics dashboard (CPU / mem / disk / procs / FDs / net / SQLite size)
/__service-data	admin	Service-metrics JSON (range/bucket/end navigation)
/__agents-data	admin	Per-identity stealth-score JSON
/__agents-timeline	admin	Detected vs missed timeline JSON
/__pow	admin	Mint a fresh PoW challenge bound to (method, path)
/__solver	admin	Browser-side PoW solver
/__status	admin	Per-identity bucket state snapshot
/__report	admin	This implementation report (PDF)
/__unban	admin	Clear ban + risk for an identity / IP / all
/__xff	admin + DEBUG=1	Header debug (redacted)

9. Appendix

8.1 Risk weights (current)

```
RISK_WEIGHTS = {
  "honeypot": 50, "honeypot-silent": 50,
  "suspicious-path": 40, "host-not-allowed": 40,
  "ai-probe": 30, "ai-enumeration": 30,
  "ua-empty": 25, "ua-blocked": 20,
  "ua-non-browser": 20, "ai-headers-empty": 15,
  "ua-too-short": 15, "behavior": 10,
  "ai-headers-incomplete": 8, "ai-no-assets": 5,
  "session-flood": 5, "upstream-404": 4,
  "rate-limit": 0, "rate-limit-ip": 0,
  "admin-ip-blocked": 0,
}
RISK_BAN_THRESHOLD = 50
RISK_BAN_THRESHOLD_NAT = 100
RISK_DECAY_HALFLIFE_SECS = 3600
RISK_BAN_DURATION_SECS = 3600
```

8.2 Files in `/data` volume

File	Purpose	UID
<code>antibot.db</code>	SQLite events / clients / timeline / bans (WAL)	65532
<code>.admin_key</code>	Operator key (mode 0600). Always mirrored from env or generated.	65532
<code>.session_key</code>	32-byte HMAC key for session cookie signing	65532
<code>.pow_key</code>	32-byte HMAC key for PoW challenge signing	65532

8.3 Detected-vs-missed reasons set

Events whose reason is in the set below count as *detected* in the agents timeline:

```
{ ua-blocked, ua-empty, ua-too-short, ua-non-browser,
  ai-probe, ai-headers-empty, ai-headers-incomplete,
  ai-enumeration, ai-no-assets, behavior,
  banned, banned-silent, honeypot, honeypot-silent,
  suspicious-path, session-flood,
  rate-limit, rate-limit-ip, host-not-allowed,
  admin-ip-blocked }
```

— End of report —

Image: `appsec-antibot-gw:1.4` · Author: Pedro Tarrinho · 2026-04-28